Universidad Nacional de San Agustín de Arequipa
Escuela Profesional de Ingeniería de Sistemas · Auditoría de Sistemas

Avance del proyecto · Grupo C

Agente Supervisor de Consentimientos

Auditoría del consentimiento sobre datos personales según la ISO/IEC 27701:2025 y la Ley N.° 29733 (AGT-CONSENT-01)

Integrantes
Daniela Choquecondo · Jhastyn Payehuanca · Daniel Bedregal

Docente
Carlos Zárate

Fecha
2026

Contenido y reparto

Parte	Expone	Diapositivas	Temas
1. Contexto y diseño	Daniel	1 – 7	Resumen de la primera entrega, problema, objetivo, diseño del agente y corpus normativo
2. Arquitectura y orquestación	Jhastyn	8 – 14	Capas, flujo automático, Fail-Fast, búsqueda híbrida, skill y controles de calidad
3. Proyecto y demostración	Daniela	15 – 21	Fallas corregidas, demostración en vivo, resultados de los 5 casos y conclusiones

El orden sigue los niveles de la rúbrica: diseño de agente, orquestación y automatización, proyecto agéntico y resultado.

Resumen de la primera entrega

No se expuso en clase; se resume para dar contexto.

Primera entrega: diseño

- TIF con la propuesta del agente
- RAG híbrido y patrón Fail-Fast
- Caso de prueba TiendaAndina
- Prototipo básico por consola

Esta entrega: implementación

- Agente completo y skill en OpenCode
- Revisión humana y controles de seguridad
- Panel web e informe en PDF
- 5 casos de prueba y 46 pruebas automáticas

El problema

1 **Mucha documentación.** Formularios, políticas de privacidad y registros que deben contrastarse control por control y artículo por artículo.

2 **Excepciones legales.** El Art. 14 de la Ley 29733 exime del consentimiento en ciertos casos; si no se revisa primero, se reportan incumplimientos que no existen.

3 **Un LLM solo no basta.** Un modelo de lenguaje puede inventar artículos o citas; un dictamen de auditoría necesita fundamento verificable.

Objetivo del agente

> Evaluar una evidencia documental y emitir un dictamen por dominio (Conforme, No Conforme o No Aplica) con la norma aplicada, la cita de la evidencia y las medidas correctivas.

Norma	Disposiciones evaluadas
ISO/IEC 27701:2025	Controles A.1.2.2, A.1.2.4, A.1.2.5, A.1.3.3, A.1.3.4 y A.1.3.5
Ley N.° 29733	Art. 5 (consentimiento), 13.5, 14 (excepciones) y 18 (información)

Diseño del agente

Nivel 1 de la rúbrica

Elemento	En nuestro agente
Objetivo	Dictaminar el ciclo del consentimiento: obtención, registro, modificación y revocación
Datos	Corpus normativo (20 fragmentos de la ISO y la Ley) y evidencias cargadas como texto en `evidencias/`
Contexto	Ficha del agente (identidad, reglas, formato de salida), reglas de auditoría y catálogo de excepciones del Art. 14
Herramientas	5 herramientas MCP: recuperar normas, verificar excepciones, analizar evidencia, emitir informe y auditoría completa

Corpus normativo: un fragmento por artículo o control

Cada **artículo** de la ley es un fragmento; el **Art. 14** se divide numeral por numeral y conserva su cabecera.

Cada **control** de la ISO es un fragmento: el Anexo A es requisito y el Anexo B, guía.

Así una excepción nunca queda separada de la regla que modifica.

Metadato	Ejemplo
`norma`	Ley N.° 29733
`articulo / numeral`	14 · numeral 5
`control`	A.1.2.5
`naturaleza`	requisito · guía · excepción
`seccion_jerarquica`	Anexo A > A.1.2.5

Arquitectura en cuatro capas

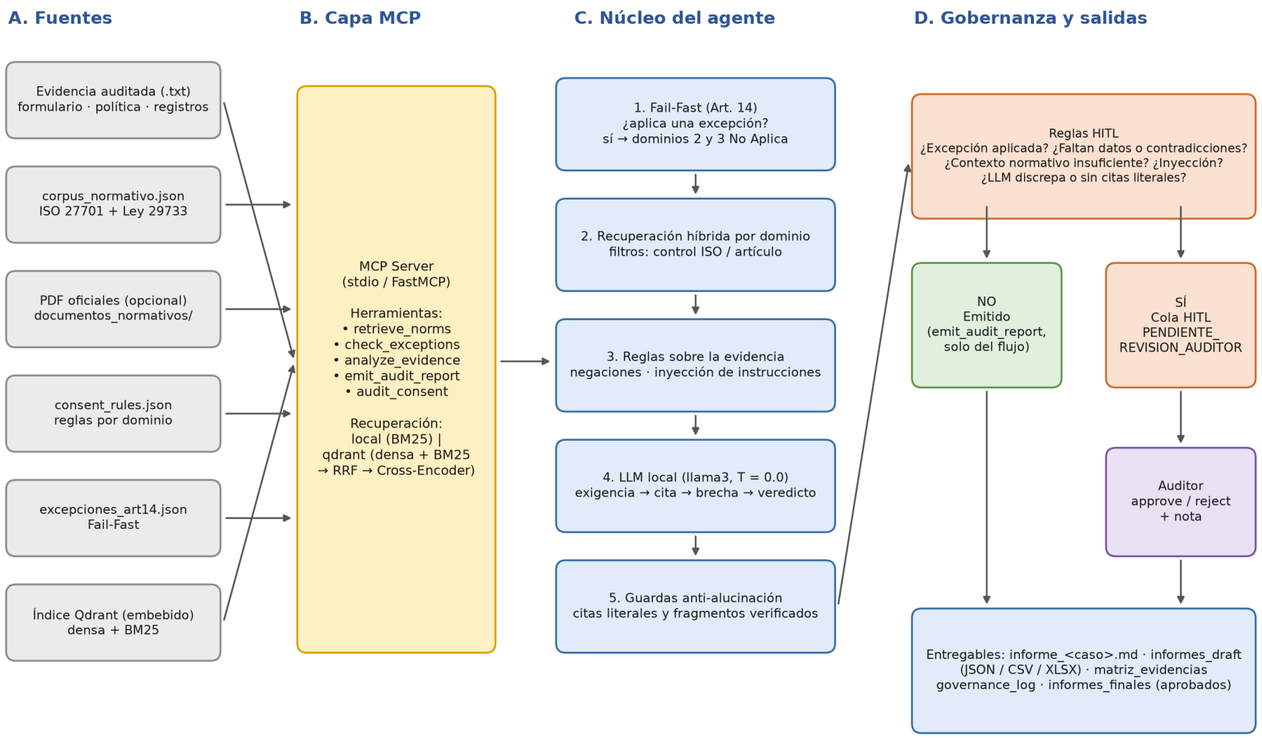


Figura 1. Fuentes, capa MCP, núcleo del agente y gobernanza. Todo corre en el equipo del auditor, sin Docker ni internet.

Flujo de auditoría

Nivel 2 de la rúbrica: orquestación y automatización

1
Fail-Fast
¿Aplica una excepción del Art. 14?

→

2
Búsqueda híbrida
Recupera la norma de cada dominio

→

3
Reglas
Detecta brechas en la evidencia

→

4
LLM local
Llama 3 razona en 4 pasos

→

5
Guardas
Verifica citas y normas

→

6
Decisión
Emite el informe o lo pasa al auditor

El flujo se repite para cada evidencia sin intervención; se lanza desde el panel o con `python run_demo.py`.

Paso 1 · Fail-Fast: primero las excepciones

¿El tratamiento encaja en una excepción del Art. 14 de la Ley 29733?

Sí, aplica

Ejemplo: apertura de una cuenta bancaria (relación contractual, Art. 14 num. 5).

Obtención y revocación quedan como **No Aplica**; el deber de información se evalúa igual.

No aplica

Ejemplo: suscripción a promociones de una tienda web.

El consentimiento es exigible y se evalúan los tres dominios completos.

Una excepción nunca ampara publicidad, marketing ni perfilamiento.

Paso 2 · Búsqueda híbrida en Qdrant

```
consulta → densa + BM25 → fusión RRF → re-ranker → fragmentos para el LLM
```

Etapa	Técnica	Para qué sirve
Densa	Embeddings multilingües	«Casilla premarcada» se relaciona con «consentimiento inequívoco» aunque no compartan palabras
Dispersa	BM25 en español	Coincidencias exactas: «Art. 14», «A.1.3.5», «revocar»
Fusión	RRF + Cross-Encoder (bge-reranker)	Combina ambas listas y deja solo los fragmentos más pertinentes

Qdrant corre embebido en el proyecto. Cada dominio filtra por metadatos y busca solo en sus controles y artículos.

Coordinación de agente, skill y herramientas

Nivel 2 de la rúbrica: skills, agentes y flujos

Pieza	Qué hace
Agente `consent-supervisor`	Identidad, protocolo y reglas; decide qué herramienta usar en cada paso
Skill `consent-audit`	El proceso de auditoría paso a paso, reutilizable
Servidor MCP	Expone las 5 herramientas para OpenCode u otros agentes
Salida JSON	Mismo formato que el agente Data Bridge del grupo, consumible por otros agentes
Automatización	`run_demo.py` audita todas las evidencias y genera los entregables

El skill consent-audit en OpenCode

Segundo entregable: del prompt al skill

Qué se comprobó

- OpenCode activó el skill solo, ante una solicitud que no lo nombraba
- Ejecutó la auditoría por consola y por la herramienta MCP
- El resultado quedó pendiente del auditor, con huella y ticket

Qué IA interviene

Asistente de OpenCode: modelo en línea (ChatGPT) que conversa y usa el skill.

Motor del agente: reglas, búsqueda híbrida y Llama 3 local en Ollama; es el que emite el dictamen.

Pasos 5 y 6 · Guardas y revisión humana

Guardas sobre la respuesta del LLM

- Solo valen citas copiadas tal cual de la evidencia
- Cada norma citada debe haber sido recuperada
- Si el LLM contradice a las reglas, se mantiene el dictamen de las reglas

Pasa al auditor cuando…

- se aplicó una excepción del Art. 14
- faltan datos o hay contradicciones
- hay instrucciones maliciosas en el texto
- el LLM discrepa o no cita nada literal

El LLM aporta el razonamiento; las reglas y el auditor tienen la última palabra.

Fallas encontradas y corregidas

Pruebas de seguridad del segundo entregable

Falla en la primera versión	Corrección
«Destinatarios:» vacío contaba como cumplimiento	Cada requisito exige contenido real
Una cita con la negación invertida pasaba	Solo se aceptan citas literales
Se podía emitir un informe inventado	Solo se emiten informes del propio flujo
Dos auditorías de una empresa compartían ID	ID único por auditoría
El ticket no quedaba guardado en la cola	Se guarda desde su creación
«Centro de diagnóstico» activaba la excepción de salud	El nombre de la empresa no es prueba

Cada corrección tiene una prueba automática que impide que la falla vuelva.

Demostración: panel del auditor

1. Elegir el caso y pulsar **Auditar**
2. Seguir el avance por dominio
3. Leer el dictamen
4. Abrir el informe en PDF
5. Aprobar o rechazar en la cola

```
python dashboard.py
127.0.0.1:8765
```

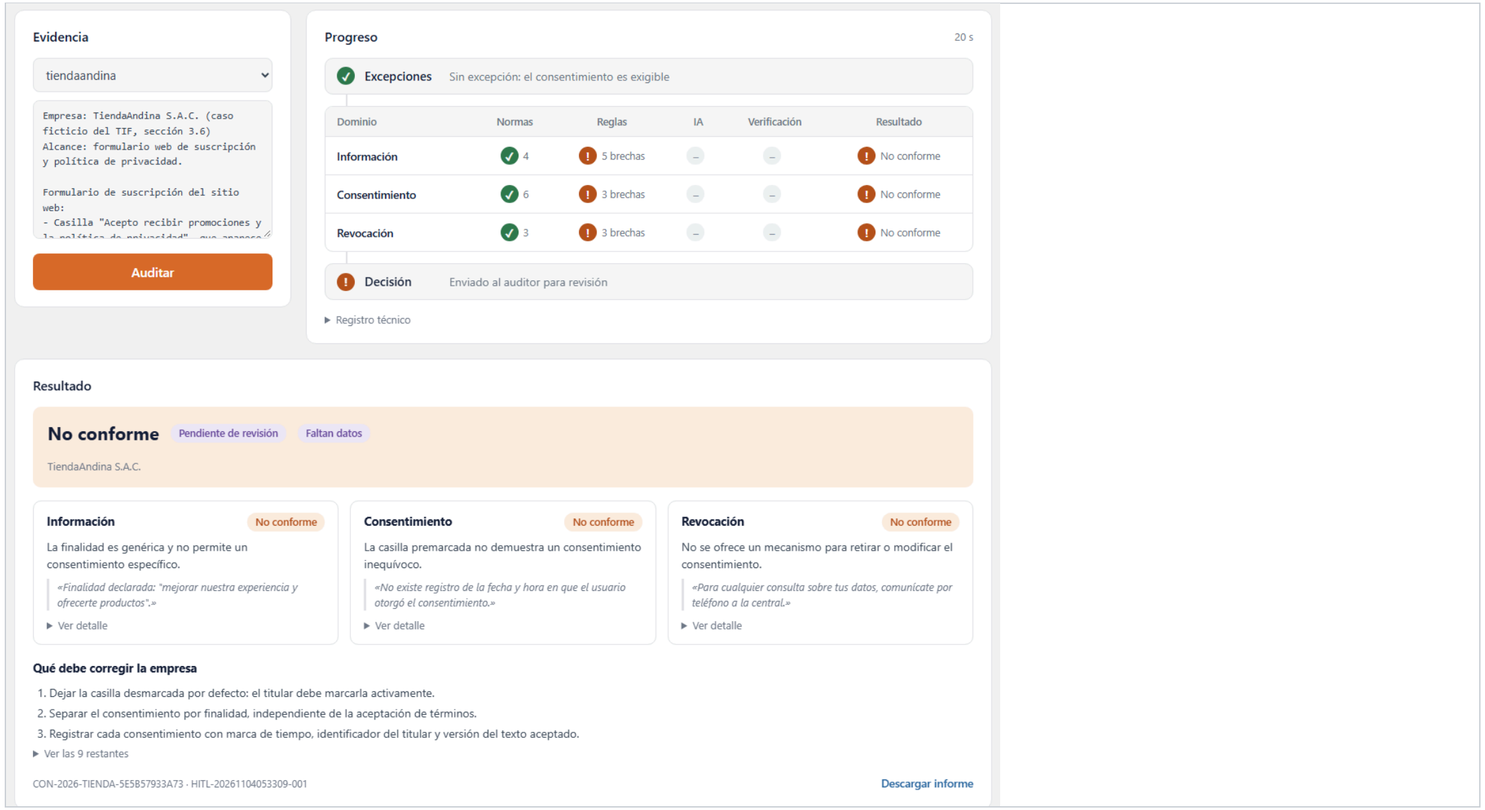


Figura 2. Caso TiendaAndina en el panel (captura de respaldo).

Cómo se usa

Nivel 3 de la rúbrica: proyecto agéntico de punta a punta

1. Cargar la evidencia

El formulario o la política se guarda como .txt en `evidencias/` o se pega en el panel.

2. Auditar

Desde el panel (`python dashboard.py`) o por consola (`python run_demo.py`).

3. Revisar resultados

Informe en PDF, Excel con los dictámenes, matriz de evidencias y cola del auditor.

Todo corre en la laptop: Qdrant embebido y Llama 3 en Ollama. 46 pruebas automáticas aprobadas y validación reproducible de los 5 casos.

Resultados de los cinco casos

Caso	Qué prueba	Dictamen	Estado
TiendaAndina	El caso del TIF	No Conforme en los 3 dominios	Al auditor (faltan datos)
Banco Andino	Excepción contractual (Art. 14)	Dominios 2 y 3 No Aplica	Al auditor (excepción)
LibreríaSur	Formulario bien diseñado	Conforme en los 3 dominios	Emitido; al auditor si llama3 discrepa
ClubFit	Instrucción maliciosa oculta	No Conforme; ataque detectado	Al auditor (inyección)
Formulario incompleto	Encabezados sin contenido	No Conforme en los 3 dominios	Al auditor (faltan datos)

`validar_skill.py` comprobó los 5 casos (5 de 5) sin simular decisiones del auditor.

Caso TiendaAndina S.A.C.

El agente reproduce la tabla 3.7 del TIF

Dominio	Evidencia citada	Dictamen	Medida principal
1. Información y propósito	«mejorar nuestra experiencia y ofrecerte productos»	No Conforme	Finalidades concretas y aviso completo
2. Obtención y registro	Casilla «Acepto recibir promociones…» premarcada	No Conforme	Casilla desmarcada y registro con fecha y hora
3. Modificación y revocación	«comunícate por teléfono a la central»	No Conforme	Baja en línea por el mismo canal
4. Excepciones legales	Fines de marketing	No aplica	Ninguna; se evalúa todo

El informe queda pendiente del auditor: no consta un canal de derechos ni un mecanismo de baja.

Evaluación con el LLM local

10 decisiones: 4 de Fail-Fast y 6 dictámenes por dominio

Modelo	Aciertos	Error observado
Llama 3 (8B)	**8 de 10**	Marcó No Conforme en casos que sí cumplían
Llama 3.1 (8B)	6 de 10	El mismo error, con más frecuencia

Por eso el LLM no decide solo: las reglas verificables dan el dictamen provisional y, si hay diferencia, el caso pasa al auditor. El agente es una herramienta de apoyo y no reemplaza al auditor.

Conclusiones y trabajo pendiente

Logrado

- Agente diseñado y skill funcionando en OpenCode
- Flujo automático con Fail-Fast y búsqueda híbrida
- Panel web, informe en PDF y 46 pruebas
- Seis fallas de seguridad corregidas

Pendiente para la tercera unidad

- Orquestarlo con los otros agentes del grupo
- Texto literal de la ISO y Art. 14 verificado
- Reglas más amplias y modelos más precisos
- Casos reales revisados por un experto

Gracias. ¿Preguntas?